

EJERCICIO B) INVESTIGACION – TP6

B – Parte1: El equipo investiga como se debe aplicar conceptos de seguridad en las distintas etapas del desarrollo de software en un ciclo de vida, detalla mediante un cuadro cuales son las buenas prácticas que se deben tener en cuenta. Dar ejemplos de aplicaciones inseguras que no utilizan seguridad en el desarrollo de software.

- 1- Comunicación y Análisis:
 - a. Incorporar y Analizar Requerimientos No Funcionales y Funcionales orientados a la Seguridad
 - b. Ejemplo:
 - i. Tiempo Limite de Inicio de Session
 - ii. Datos Sencibles Encriptados
- 2- Diseño:
 - a. Buscar reducir riesgos de seguridad en el Diseno según las Capas y Tecnologia Specifica
 - i. Lenguaje Programacion: L. Seguro Memoria, L. Tipado Fuerte
 - ii. Capa Logica Negocio
 1. Programacion Defensiva
 - iii. Capa Vista, Controlador
 1. Comunicación HTTPS, encriptada, Metodos HTTPS seguros
- 3- Construcción:
 - a. Escribir Código Libre de Vulnerabilidades, Errores de Seguridad
 - i. Actividades Sombrilla Código
 - ii. Credenciales HardCodeadas
- 4- Despliegue:
 - a. Programación Ofensiva: Testear y Buscar Vulnerabilidades antes de pasar a PRD
 - b. Garantizar Entorno Seguro

B - Parte 2 : Ejemplos de Aplicaciones Inseguras en el Desarrollo de Software

Cuando los proyectos de software omiten la seguridad en su ciclo de vida, se producen fallas críticas que pueden ser explotadas de forma trivial por actores maliciosos

- **Validación de Autenticación en el Frontend (Client-Side Authentication):**
 - Verificación del User y Password directamente en el Frontend-Navegador
 - `'if (usuario == "admin" && password == "1234") { window.location = "panel_privado.html"; }'`.
- **Almacenamiento y Transmisión de Contraseñas en Texto Plano**
 - Aplicación envía credenciales a través de peticiones HTTP no cifradas (/ GET), almacena en la DB (DB: 'password' = '123456').

- **SQL Injection**

- Sentencias SQL sin sanitizar, atacante puede ingresar en el campo de texto: ' OR '1'='1' -- y la consulta resultante retornará verdadero sin importar la contraseña:
 - `String query = "SELECT * FROM usuarios WHERE email = '" + emailInput + "' AND password = '" + passInput + "';";`

- **Referencia Directa Insegura a Objetos (IDOR - Insecure Direct Object Reference)**

- API expone rutas como 'GET /api/usuario/4521/datos_bancarios' y el backend entrega la información confiando ciegamente en el ID recibido, sin verificar si el usuario autenticado tiene permisos para ver ese registro específico.

B - Parte 3 : Que significa que una clave este encriptada

Se hace referencia a que la contraseña no se almacena en su texto plano original, sino que ha sido transformada mediante un proceso criptográfico de protección.

B - Parte 4 : Implementacion BCrypt para encriptacion

El video de referencia ('Cómo Generar Contraseñas Encriptadas en Spring Boot con Java' - Canal Brain Data Center: <https://www.youtube.com/watch?v=7-muJODgU6g>) enseña la implementación profesional de seguridad de contraseñas en el ecosistema Java / Spring Framework utilizando el módulo Spring Security y la clase BCryptPasswordEncoder.